

Amenly

REST API REFERENCE

AI-Powered Governance, Risk & Compliance Platform

Base URL: `/api/v1` · 77 endpoints · Version 1.0.1

Generated from the live OpenAPI schema

Overview

This document describes every endpoint of the Amenly backend API, grouped by domain. For each endpoint it lists the HTTP method and path, what it does, whether authentication is required, its parameters and request body, and the shape of its response.

AUTHENTICATION

Most endpoints require a **Bearer JWT** access token obtained from `POST /api/v1/auth/login`, sent as `Authorization: Bearer <token>`. A single active token is enforced per user (a new login revokes the previous token).

STANDARD RESPONSE ENVELOPE

Unless noted otherwise, successful responses are wrapped as:

<code>success</code>	<code>boolean</code>	Always true on success.
<code>message</code>	<code>string</code>	Human-readable status message.
<code>data</code>	<code>object</code>	The endpoint-specific payload (detailed per endpoint below).

Errors return an HTTP 4xx/5xx status with a JSON body `{ "detail": "..." }`.

Contents

Assessments	15	Infrastructure Assets	6
Authentication	8	Organizations	13
Dashboard	4	Permissions & Access Control	8
Frameworks	12	RAG System	3
General	2	Users	6

Assessments

GET /api/v1/assessments

List Assessments

List all assessments for the organization. Requires: VIEW_ALL_SESSIONS or VIEW_OWN_SESSIONS permission

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

POST /api/v1/assessments

Create Assessment

Create a new assessment (Admin only). Requires: START_ASSESSMENT permission

 Bearer JWT required

REQUEST BODY

FIELD	TYPE	DESCRIPTION
name required	string	
framework_id required	string (uuid)	

RESPONSE

201 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

POST /api/v1/assessments/answers

Save Assessment Answer

Save an assessment answer. Requires: VIEW_OWN_SESSIONS permission

 Bearer JWT required

REQUEST BODY

FIELD	TYPE	DESCRIPTION
answer_text required	string	
evidence_urls	string[] null	
session_id required	string (uuid)	
question_id required	string (uuid)	
position_id	string (uuid) null	

RESPONSE

201 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

GET /api/v1/assessments/sessions/{session_id}

Get Assessment Session

Get assessment session details. Requires: VIEW_OWN_SESSIONS permission

 Bearer JWT required

PARAMETERS

session_id required	path · string (uuid)
------------------------------------	----------------------

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

GET /api/v1/assessments/sessions/{session_id}/chat

Get Chat History

Get chat history for an assessment session. Requires: VIEW_OWN_SESSIONS permission

 Bearer JWT required

PARAMETERS

session_id required path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

POST /api/v1/assessments/sessions/{session_id}/chat

Send Chat Message

Send a chat message in assessment session. Requires: VIEW_OWN_SESSIONS permission Note: This endpoint saves the message. AI response will be handled by WebSocket.

 Bearer JWT required

PARAMETERS

session_id required path · string (uuid)

REQUEST BODY

FIELD	TYPE	DESCRIPTION
message_text required	string	
session_id	string (uuid) null	

RESPONSE

201 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

POST /api/v1/assessments/sessions/{session_id}/complete

Complete Assessment Session

Complete an assessment session. Requires: VIEW_OWN_SESSIONS permission

 Bearer JWT required

PARAMETERS

session_id required path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

GET /api/v1/assessments/{assessment_id}

Get Assessment

Get assessment details. Requires: VIEW_ALL_SESSIONS or VIEW_OWN_SESSIONS permission

 Bearer JWT required

PARAMETERS

assessment_id required path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

POST /api/v1/assessments/{assessment_id}/advance-phase

Advance Phase

Snapshot the baseline score and open the remediation (second) pass (Admin only).

 Bearer JWT required

PARAMETERS

assessment_id required path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

POST /api/v1/assessments/{assessment_id}/close

Close Campaign

Close the campaign and lock in the final score (Admin only).

 Bearer JWT required

PARAMETERS

assessment_id required path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

POST `/api/v1/assessments/{assessment_id}/launch`

Launch Campaign

Launch the assessment campaign (Admin only). Opens the baseline phase.

 Bearer JWT required

PARAMETERS

`assessment_id` required path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
<code>success</code> required	<code>boolean</code>	
<code>message</code> required	<code>string</code>	
<code>data</code>	<code>object null</code>	

422 Validation Error

FIELD	TYPE	DESCRIPTION
<code>detail</code>	<code>ValidationError[]</code>	

GET `/api/v1/assessments/{assessment_id}/overview`

Campaign Overview

Before/after scores + participation summary for the admin dashboard.

 Bearer JWT required

PARAMETERS

`assessment_id` required path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
<code>success</code> required	<code>boolean</code>	
<code>message</code> required	<code>string</code>	
<code>data</code>	<code>object null</code>	

422 Validation Error

FIELD	TYPE	DESCRIPTION
<code>detail</code>	<code>ValidationError[]</code>	

GET /api/v1/assessments/{assessment_id}/sessions

List Campaign Sessions

List every member's session for the assessment (Admin only).

 Bearer JWT required

PARAMETERS

assessment_id required path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

POST /api/v1/assessments/{assessment_id}/sessions/start

Start Assessment Session

Start a new assessment session for the current user. Requires: VIEW_OWN_SESSIONS permission

 Bearer JWT required

PARAMETERS

assessment_id required path · string (uuid)

RESPONSE

201 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

GET /api/v1/assessments/{assessment_id}/sessions/{session_id}/chat

Get Member Session Chat

Read a member's full interview transcript for the assessment (Admin only).

 Bearer JWT required

PARAMETERS

assessment_id	required	path · string (uuid)
session_id	required	path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success	required	boolean
message	required	string
data		object null

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail		ValidationError[]

Authentication

POST /api/v1/auth/change-password

Change Password

Change the authenticated user's password (requires the current password). All existing tokens are revoked, so the user must log in again.

 Bearer JWT required

REQUEST BODY

FIELD	TYPE	DESCRIPTION
current_password	required	string
new_password	required	string

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success	required	boolean
message	required	string
data		object null

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail		ValidationError[]

GET /api/v1/auth/debug/token-status

Debug Token Status

Debug endpoint to check token status in Redis. Only available in development mode.

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

POST /api/v1/auth/join-request

Request To Join

Request to join an existing organization using its invite code. No account is created and no token is returned — an organization admin must approve the request before the user can log in.

 Public

REQUEST BODY

FIELD	TYPE	DESCRIPTION
email required	string (email)	
password required	string	
full_name required	string	
invite_code required	string	

RESPONSE

201 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

POST /api/v1/auth/login

Login

Login user and return tokens.

 Public

REQUEST BODY

FIELD	TYPE	DESCRIPTION
email required	string (email)	
password required	string	

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
access_token required	string	
refresh_token required	string	
token_type required	string	
user required	UserResponse	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

POST /api/v1/auth/logout

Logout

Logout user by revoking all active tokens.

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

GET /api/v1/auth/me

Get Me

Get current user profile.

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

POST /api/v1/auth/refresh

Refresh Token

Refresh access token using refresh token. Old access token will be revoked.

 Public

REQUEST BODY

FIELD	TYPE	DESCRIPTION
refresh_token required	string	

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
access_token required	string	
refresh_token required	string	
token_type required	string	
user required	UserResponse	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

POST /api/v1/auth/register

Register

Register a new user and organization.

 Public

REQUEST BODY

FIELD	TYPE	DESCRIPTION
email required	string (email)	
password required	string	
full_name required	string	
organization_name required	string	
department_name	string null	
position_name	string null	

RESPONSE

201 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

Dashboard

GET /api/v1/dashboard/assets

Get Assets Dashboard

Get assets dashboard with role-based filtering. org_admin: Sees all organization assets org_member: Sees only assets they own

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

GET /api/v1/dashboard/compliance

Get Compliance Dashboard

Get compliance dashboard (Admin only). Requires: VIEW_ORG_TOTAL_SCORE permission

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

GET /api/v1/dashboard/overview

Get Dashboard Overview

Get dashboard overview with role-based data filtering. org_admin: Sees full organization overview org_member: Sees personal assessment progress only

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

GET /api/v1/dashboard/risks

Get Risks Dashboard

Get risks dashboard with role-based filtering. org_admin: Sees all organization risks org_member: Sees only risks related to their owned assets

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

Frameworks

GET /api/v1/frameworks/

List all frameworks

Get a paginated list of all compliance frameworks with optional filtering by type, category, region, and mandatory status

 Bearer JWT required

PARAMETERS

skip	query · integer	Number of records to skip
limit	query · integer	Maximum number of records to return
framework_type	query · app__models__enums__FrameworkType null	Filter by framework type (STANDARD, REGULATION, GUIDELINE)
category	query · FrameworkCategory null	Filter by category
region	query · string null	Filter by region (e.g., 'United States', 'European Union')
is_mandatory	query · boolean null	Filter by mandatory status
search	query · string null	Search in framework name or description

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

POST /api/v1/frameworks/

Create new framework

Create a new compliance framework (Admin only)

 Bearer JWT required

REQUEST BODY

FIELD	TYPE	DESCRIPTION
name required	string	Framework name (e.g., ISO 27001, GDPR)
version	string null	Framework version (e.g., 2022, 4.0.1)
description	string null	Detailed description of the framework
framework_type required	app__models__enums__FrameworkType	Type: STANDARD, REGULATION, or GUIDELINE
category required	FrameworkCategory	Primary category of the framework
region	string null	Geographic region (e.g., 'Global', 'United States', 'European Union')
industry	string null	Target industry (e.g., 'Healthcare', 'Financial', 'General')
is_mandatory	boolean	Whether compliance is legally required
official_url	string null	Official documentation URL

RESPONSE

201 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

POST /api/v1/frameworks/associate

Associate frameworks with organization

Add frameworks to organization by IDs, types, or all frameworks (Admin only)

 Bearer JWT required

REQUEST BODY

FIELD	TYPE	DESCRIPTION
framework_ids	string (uuid)[] null	List of specific framework IDs to add
framework_types	app__models__enums__FrameworkType[] null	Add all frameworks of these types
add_all	boolean	Add all available frameworks

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

GET /api/v1/frameworks/available/all

Get all available frameworks

Get all frameworks in the system (not just organization's frameworks)

 Bearer JWT required

PARAMETERS

skip	query · integer	Number of records to skip
limit	query · integer	Maximum number of records to return
framework_type	query · app__models__enums__FrameworkType null	Filter by framework type
category	query · FrameworkCategory null	Filter by category
search	query · string null	Search in framework name or description

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

GET /api/v1/frameworks/categories

Get available framework categories

Get list of all available framework categories

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

DELETE /api/v1/frameworks/dissociate/{framework_id}

Remove framework from organization

Dissociate a framework from the organization (Admin only)

 Bearer JWT required

PARAMETERS

framework_id required path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

GET /api/v1/frameworks/regions

Get available regions

Get list of all regions that have frameworks

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

GET /api/v1/frameworks/stats

Get framework statistics

Get comprehensive statistics about frameworks including counts by type, category, region, and mandatory status

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

GET /api/v1/frameworks/types

Get available framework types

Get list of all available framework types (STANDARD, REGULATION, GUIDELINE)

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

DELETE /api/v1/frameworks/{framework_id}

Delete framework

Delete a framework (Admin only)

 Bearer JWT required

PARAMETERS

framework_id required path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

GET /api/v1/frameworks/{framework_id}

Get framework details

Get detailed information about a specific framework

 Bearer JWT required

PARAMETERS

framework_id required path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

PATCH /api/v1/frameworks/{framework_id}

Update framework

Update an existing framework (Admin only)

 Bearer JWT required

PARAMETERS

framework_id required path · string (uuid)

REQUEST BODY

FIELD	TYPE	DESCRIPTION
name	string null	Framework name
version	string null	Framework version
description	string null	Framework description
framework_type	app__models__enums__FrameworkType null	Framework type
category	FrameworkCategory null	Framework category
region	string null	Geographic region
industry	string null	Target industry
is_mandatory	boolean null	Is legally required?
official_url	string null	Official URL

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

General

GET /

Root

Root endpoint - Welcome message

 Public

RESPONSE

200 Successful Response

GET /health

Health Check

Health check endpoint

 Public

RESPONSE

200 Successful Response

Infrastructure Assets

GET /api/v1/assets

List Infrastructure Assets

List infrastructure assets for the organization. Requires: VIEW_ASSETS permission Optionally filter by asset type (server, database, api, cloud_service, etc.)

 Bearer JWT required

PARAMETERS

asset_type query · string | null

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

POST /api/v1/assets/extract

Extract Assets

Extract infrastructure assets from conversation text using AI. Requires: VIEW_ASSETS permission This endpoint analyzes the provided text and automatically extracts infrastructure assets (servers, databases, APIs, cloud services, etc.)

 Bearer JWT required

REQUEST BODY

FIELD	TYPE	DESCRIPTION
message_text required	string	
session_id	string (uuid) null	
message_id	string (uuid) null	

RESPONSE

201 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

GET /api/v1/assets/map

Infrastructure Map

Infrastructure topology map (nodes + edges) for the dashboard (Admin).

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

POST /api/v1/assets/scan-vulnerabilities

Scan Vulnerabilities

Scan all infrastructure assets against NVD and refresh risk/status (Admin).

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

GET /api/v1/assets/statistics

Get Asset Statistics

Get statistics about infrastructure assets. Requires: VIEW_ASSETS permission Returns counts by type and recent assets.

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

GET /api/v1/assets/vulnerabilities

List Vulnerabilities

List detected vulnerabilities for the organization.

 Bearer JWT required

PARAMETERS

only_open query · boolean

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

Organizations

GET /api/v1/orgs/departments

List Departments

List all departments in the current organization.

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

POST /api/v1/orgs/departments

Create Department

Create a new department in the organization (Admin only).

 Bearer JWT required

REQUEST BODY

FIELD	TYPE	DESCRIPTION
name required	string	
description	string null	
organization_id required	string (uuid)	

RESPONSE

201 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

DELETE /api/v1/orgs/departments/{dept_id}

Delete Department

Delete a department (Admin only).

 Bearer JWT required

PARAMETERS

dept_id required path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

GET /api/v1/orgs/departments/{dept_id}/positions

List Positions

List all positions within a specific department.

 Bearer JWT required

PARAMETERS

dept_id required path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

POST `/api/v1/orgs/invite-code/regenerate`

Regenerate Invite Code

Generate a fresh single-use invite code for the organization (Admin only). The previous code is replaced. Each code can be used by exactly one person to request to join; once used it is consumed and a new one must be generated.

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
<code>success</code> required	<code>boolean</code>	
<code>message</code> required	<code>string</code>	
<code>data</code>	<code>object null</code>	

GET `/api/v1/orgs/join-requests`

List Join Requests

List pending requests from people who want to join the admin's organization.

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
<code>success</code> required	<code>boolean</code>	
<code>message</code> required	<code>string</code>	
<code>data</code>	<code>object null</code>	

POST `/api/v1/orgs/join-requests/{request_id}/approve`

Approve Join Request

Approve a pending join request — creates the member account (Admin only).

 Bearer JWT required

PARAMETERS

`request_id` required path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
<code>success</code> required	boolean	
<code>message</code> required	string	
<code>data</code>	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
<code>detail</code>	ValidationError[]	

POST `/api/v1/orgs/join-requests/{request_id}/reject`

Reject Join Request

Reject a pending join request (Admin only).

 Bearer JWT required

PARAMETERS

`request_id` required path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
<code>success</code> required	boolean	
<code>message</code> required	string	
<code>data</code>	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
<code>detail</code>	ValidationError[]	

GET /api/v1/orgs/me

Get My Organization

Get current user's organization details including departments and positions.

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

PATCH /api/v1/orgs/me

Update My Organization

Update organization settings (Admin only).

 Bearer JWT required

REQUEST BODY

FIELD	TYPE	DESCRIPTION
name	string null	
domain	string null	
is_active	boolean null	

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

POST /api/v1/orgs/positions

Create Position

Create a new position within a department (Admin only).

 Bearer JWT required

REQUEST BODY

FIELD	TYPE	DESCRIPTION
name required	string	
level	string null	
department_id required	string (uuid)	

RESPONSE

201 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

DELETE /api/v1/orgs/positions/{pos_id}

Delete Position

Delete a position (Admin only).

 Bearer JWT required

PARAMETERS

pos_id required	path · string (uuid)
--------------------------------	----------------------

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

PUT `/api/v1/orgs/profile`

Update Company Profile

Save the organization's company profile and mark onboarding complete (Admin only). This is the first step of the assessment: members cannot start an assessment until the admin completes this profile.

 Bearer JWT required

REQUEST BODY

FIELD	TYPE	DESCRIPTION
name	string null	
industry	string null	
company_size	string null	
region	string null	
website	string null	
description	string null	

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

Permissions & Access Control

GET `/api/v1/permissions/catalog`

Get permissions catalog

Get list of all available permissions with descriptions

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

GET /api/v1/permissions/check/{permission}

Check if I have permission

Check if current user has a specific permission

 Bearer JWT required

PARAMETERS

permission required path · string

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

POST /api/v1/permissions/grant

Grant permissions to user

Grant additional permissions to a user (Admin only)

 Bearer JWT required

REQUEST BODY

FIELD	TYPE	DESCRIPTION
user_id required	string (uuid)	User to grant permissions to
permissions required	Permission[]	Permissions to grant
notes	string null	Notes about why permissions were granted
expires_at	string (date-time) null	Optional expiry date for permissions

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

GET /api/v1/permissions/me

Get my permissions

Get current user's permissions (role-based + custom)

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

POST /api/v1/permissions/revoke

Revoke permissions from user

Revoke custom permissions from a user (Admin only)

 Bearer JWT required

REQUEST BODY

FIELD	TYPE	DESCRIPTION
user_id required	string (uuid)	User to revoke permissions from
permissions required	Permission[]	Permissions to revoke

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

GET /api/v1/permissions/roles

Get role permissions

Get default permissions for each role

 Bearer JWT required

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

GET /api/v1/permissions/user/{user_id}

Get user permissions

Get permissions for a specific user (Admin only)

 Bearer JWT required

PARAMETERS

user_id required path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

DELETE `/api/v1/permissions/user/{user_id}/all`

Revoke all custom permissions

Revoke all custom permissions from a user (Admin only)

 Bearer JWT required

PARAMETERS

`user_id` required `path · string (uuid)`

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
<code>success</code> required	<code>boolean</code>	
<code>message</code> required	<code>string</code>	
<code>data</code>	<code>object null</code>	

422 Validation Error

FIELD	TYPE	DESCRIPTION
<code>detail</code>	<code>ValidationError[]</code>	

RAG System

GET `/api/v1/rag/health`

Health Check

Check RAG system health Verifies: - Ollama connection - Available models - Qdrant connection

 Public

RESPONSE

200 Successful Response

POST /api/v1/rag/query

Query Rag

Query RAG system with compliance question This endpoint: 1. Generates query embedding 2. Searches Qdrant for relevant chunks 3. Builds context from retrieved documents 4. Generates answer using LLM 5. Returns structured response with sources Example: ``json { "question": "What does ISO 27001 require for MFA?", "framework": "ISO27001", "top\_k": 5 } ``

 Bearer JWT required

REQUEST BODY

FIELD	TYPE	DESCRIPTION
question required	string	User question
framework	app_ai_rag_schemas_FrameworkType null	Filter by specific framework
top_k	integer	Number of chunks to retrieve
score_threshold	number	Minimum similarity score
include_metadata	boolean	Include chunk metadata in response

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	Query success status
message required	string	Status message
data	RAGAnswer null	Structured answer with sections, summary, and metadata

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

POST /api/v1/rag/search

Search Documents

Semantic search without LLM generation Returns relevant document chunks without generating an answer.
Useful for: - Exploring available content - Finding specific controls or sections - Debugging retrieval quality

 Bearer JWT required

REQUEST BODY

FIELD	TYPE	DESCRIPTION
query required	string	Search query
framework	app_ai_rag_schemas_FrameworkType null	Filter by framework
top_k	integer	Number of results
score_threshold	number	Minimum score

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

Users

GET /api/v1/users/

Get Users

Get users list (Admin only).

 Bearer JWT required

PARAMETERS

skip	query · integer
limit	query · integer

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

POST /api/v1/users/**Add a member to your organization (Admin only)**

Create a new user inside the current admin's organization.

 Bearer JWT required

REQUEST BODY

FIELD	TYPE	DESCRIPTION
email required	string (email)	
password required	string	
full_name	string null	
role	UserRole	
position_id	string (uuid) null	

RESPONSE

201 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

PATCH /api/v1/users/me**Update my own profile**

Update the authenticated user's own profile (name/email).

 Bearer JWT required

REQUEST BODY

FIELD	TYPE	DESCRIPTION
full_name	string null	
email	string (email) null	

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

DELETE /api/v1/users/{user_id}

Delete User

Delete user (Admin only - soft delete).

 Bearer JWT required

PARAMETERS

user_id required path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

GET /api/v1/users/{user_id}

Get User

Get single user details.

 Bearer JWT required

PARAMETERS

user_id required path · string (uuid)

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	

PATCH /api/v1/users/{user_id}

Update User

Update user (Admin only).

 Bearer JWT required

PARAMETERS

user_id required path · string (uuid)

REQUEST BODY

FIELD	TYPE	DESCRIPTION
email	string (email) null	
full_name	string null	
role	UserRole null	
is_active	boolean null	
position_id	string (uuid) null	

RESPONSE

200 Successful Response

FIELD	TYPE	DESCRIPTION
success required	boolean	
message required	string	
data	object null	

422 Validation Error

FIELD	TYPE	DESCRIPTION
detail	ValidationError[]	